

Audit SSI

Chapitre 3 – Principes, typologies et cadre normatif de l'audit des SI

Rappel

Définition et composants d'un SI ;

Enjeux de la sécurité : confidentialité, intégrité, disponibilité, traçabilité (CIDT) ;

Principales menaces, types d'attaques et vulnérabilités ;

Importance stratégique de la cybersécurité dans l'organisation.

Rappel

Rôles et responsabilités : RSSI, DSI, auditeur, audité... ;

Organisation d'un Système de Management de la Sécurité de l'Information (SMSI) ;

Politiques, chartes, procédures de sécurité ;

Positionnement de l'audit dans la gouvernance globale de la sécurité.

Exercice des chapitres précédents

Exercice 1 et Exercice 2 Chapitre 1

Exercice 2 Chapitre 2

1. Définition de l'audit des systèmes d'information

En informatique, le terme « audit » a émergé dans les années 70 et a été utilisé de manière assez vague.

Un "audit de sécurité de l'information" est désormais perçu comme une évaluation de la conformité aux règles de sécurité définies dans une politique de sécurité, ou, à défaut, par un ensemble de standards de sécurité.

Pour effectuer un audit, il est essentiel de disposer d'un référentiel, c'est-à-dire un ensemble de règles organisationnelles, procédurales et/ou techniques de référence.

Ce référentiel sert de base pour évaluer le niveau de sécurité sur le terrain par rapport à un objectif défini.

1. Définition de l'audit des systèmes d'information

Pour être efficace, le référentiel doit être :

Complet : Il doit couvrir toutes les caractéristiques nécessaires, incluant les aspects système, réseau, télécoms, applicatifs, ainsi que les aspects techniques et organisationnels.

Homogène : Chaque caractéristique évaluée doit avoir une importance cohérente avec l'ensemble.

Pragmatique : Il doit être facile à mesurer, qualifier et contrôler, un aspect souvent négligé.

L'audit consiste ainsi à vérifier dans quelle mesure les règles de sécurité sont appliquées dans le système d'information, par rapport aux règles censées être en place selon les processus définis.

L'audit est avant tout un état des lieux.

1. Définition de l'audit des systèmes d'information

Consiste à une intervention réalisée par une personne **indépendante** et **extérieure** au service audité, qui permet d'analyser tout ou une partie d'une organisation informatique, d'établir un constat des points **forts** et des **points faibles** et dégager ainsi les recommandations d'amélioration.

Autrement dit, L'audit de la sécurité du SI peut aussi être défini l'évaluation des risques des activités informatiques, dans le but d'apporter une diminution de ceux-ci et d'améliorer la maîtrise des systèmes d'information et des risques.

L'audit est un exercice d'évaluation basé sur **des faits**. Cette évaluation met en évidence les forces et les faiblesses de l'organisme ou du système audité. Les résultats de l'audit sont communiqués à la direction qui prendra alors les mesures nécessaires et appropriées.

1. Définition de l'audit des systèmes d'information

L'audit est également un processus **méthodique**, **indépendant** et **documenté**, permettant d'obtenir des **preuves** objectives et de les évaluer de manière objective pour déterminer dans quelle mesure les critères d'audit sont satisfaits,

Autrement dit, auditer signifie demander à l'organisation auditée ce qu'elle fait et comment elle le fait, afin de vérifier si les pratiques sont conformes aux politiques, procédures et processus de l'organisme.

2. Rôles et objectifs de l'audit

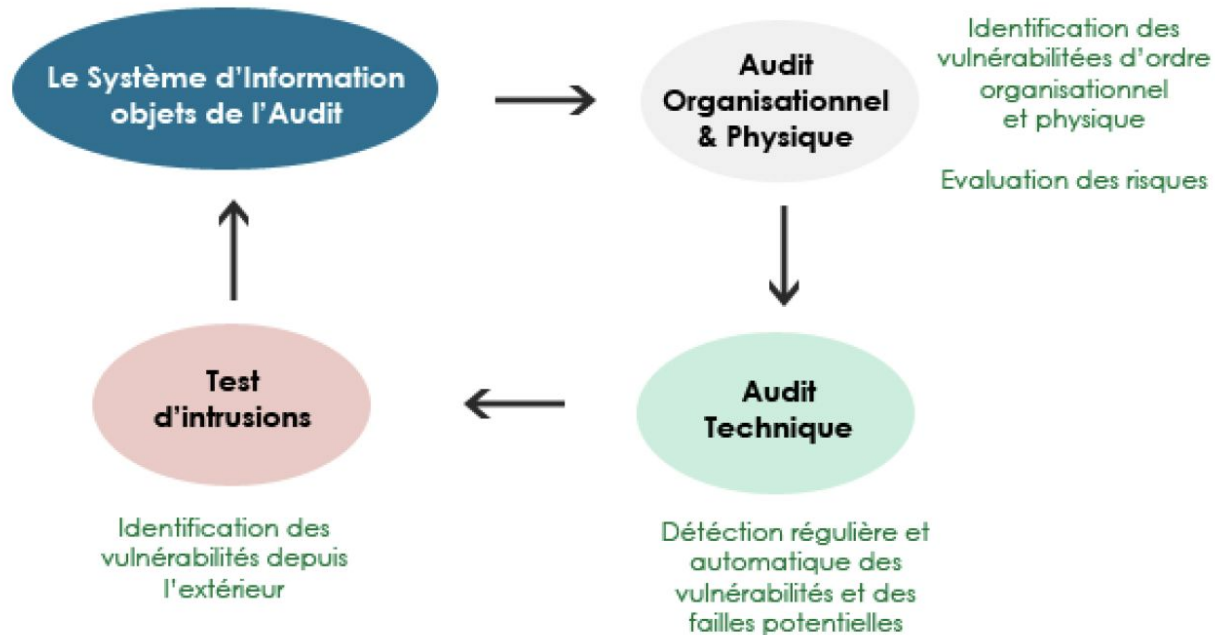
L'audit de sécurité poursuit plusieurs objectifs, parmi lesquels :

Identifier les écarts par rapport aux bonnes pratiques de sécurité, en mettant en évidence les faiblesses et les vulnérabilités du système.

Proposer des actions correctives pour renforcer la sécurité du système d'information et combler les écarts identifiés.

En outre, l'audit de sécurité du système d'information est un outil d'évaluation de la conformité, permettant de vérifier que les pratiques et procédures respectent bien la politique de sécurité ou les standards définis.

3. Cycle de vie de l'audit



4. Typologies d'audit

L'audit peut se décliner en plusieurs types selon l'objectif poursuivi et le périmètre évalué



4. Typologies d'audit

L'audit peut se décliner en plusieurs types selon l'objectif poursuivi et le périmètre évalué

4.1. Audit de conformité

Vérifie l'alignement des pratiques avec un référentiel donné : politique interne, loi, norme (ex. ISO/IEC 27001, RGPD, PCI-DSS).

Exemple : audit ISO 27001 pour s'assurer du respect des exigences de la norme.



4. Typologies d'audit

L'audit peut se décliner en plusieurs types selon l'objectif poursuivi et le périmètre évalué

4.2. Audit organisationnel

Évalue les processus de gouvernance, les rôles et responsabilités, la gestion des accès, la documentation des procédures, etc.

Objectif : vérifier que les fonctions critiques du SI sont correctement pilotées et supervisées.



4. Typologies d'audit

L'audit peut se décliner en plusieurs types selon l'objectif poursuivi et le périmètre évalué

4.3. Audit technique

Consiste à analyser les composants techniques du SI (serveurs, réseaux, applications, bases de données) pour identifier les failles de sécurité, les erreurs de configuration, les vulnérabilités ou les défauts de mise à jour.

Le modèle VPTCS

	V Visibilité	P Perception	T Technique	C Contenus	S Services
Objectif	 Être rencontré par ses utilisateurs potentiels	 Être utilisable et correctement perçu par ses utilisateurs	 Fonctionner correctement	 Fournir de l'information de qualité	 Proposer, accompagner, produire des services de qualité
Exemples de secteurs / d'activités recouverts	- Référencement - Positionnement - Webmarketing - Communication	- Ergonomie - Accessibilité - Webdesign - Navigation	- Sécurité - Hébergement - QoS - Performance - Conformité W3C	- Rédaction - Traduction - Netiquette - Fraicheur	- E-Commerce - Logistique - Support / garantie - Relation client (CRM)

4. Typologies d'audit

L'audit peut se décliner en plusieurs types selon l'objectif poursuivi et le périmètre évalué

2.4. Audit intrusif (ou test d'intrusion simulé)

L'objectif est de simuler des attaques réelles afin d'évaluer la résistance du système face à des comportements malveillants.

Méthodes utilisées : pentest boîte noire/blanche/grise, analyse dynamique, exploitation de failles.



4. Typologies d'audit

L'audit peut se décliner en plusieurs types selon l'objectif poursuivi et le périmètre évalué

2.5. Audit mixte

Combine plusieurs des types ci-dessus dans une approche holistique, souvent utilisée dans les missions de grande ampleur (audit annuel, due diligence, etc.).

Objectifs de l'audit mixte en risque infectieux



- Réaliser au contact des unités un constat exhaustif des réussites et des difficultés de mise en place d mesures de gestion du risque infectieux
- Mesurer la connaissance, la compréhension et l'appropriation des moyens de prévention des infections associées aux soins
- Identifier les points forts et les points à améliorer
- Mettre en œuvre rapidement des solutions pragmatiques et adaptées au terrain

5. Méthodologie et Approche d'audit

Méthodologie et Approche d'audit

Il nous reste un sujet à traiter : le déroulement des audits, présentant l'approche et la méthodologie d'audit.

Approche : Manière d'approcher un problème un sujet

Méthodologie: Ensemble me méthode et de technique d'un domaine particulier

Dans les prochaines Slides je vous présenterai une approche générale d'audit, qui pourra être intégrée et adopter dans vos missions d'audit.

Cette approche générale vous garantira une homogénéité des pratiques d'audit structurées et cadencées au moyen de phases et de jalons clés.



5. Méthodologie et Approche d'audit

Méthodologie et Approche d'audit

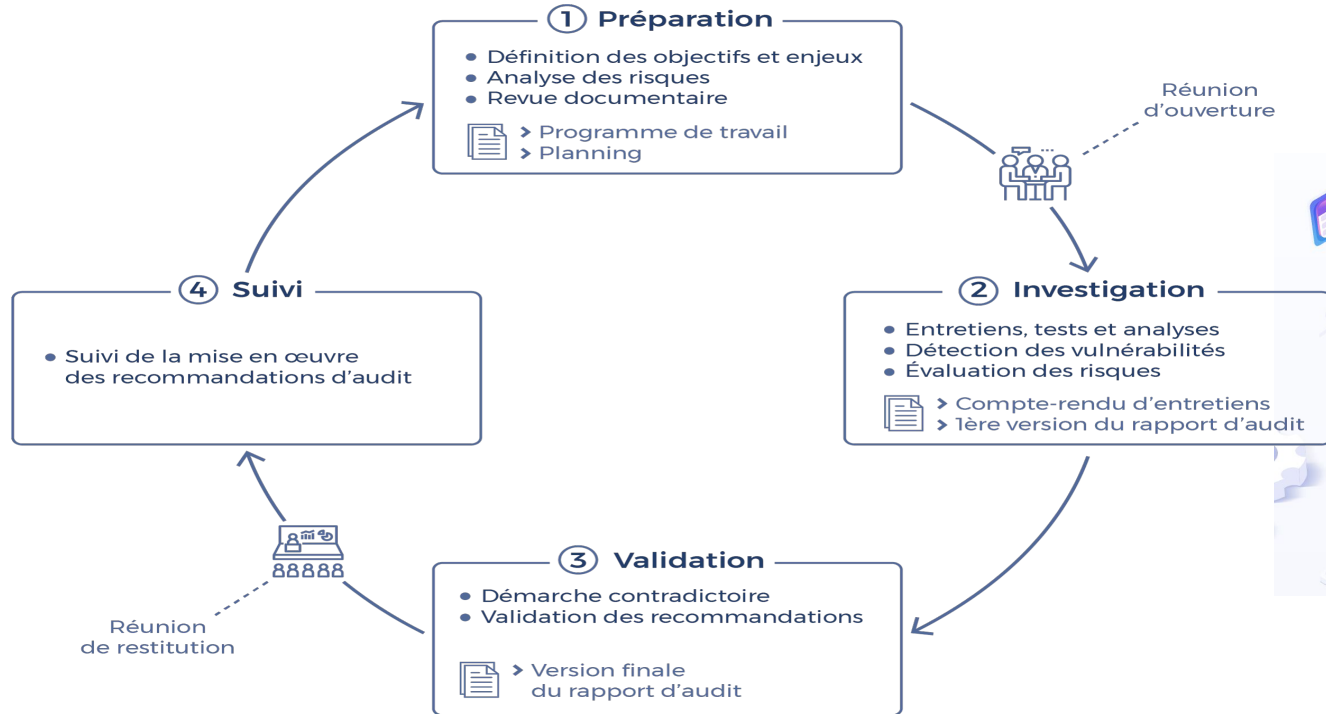
Il nous reste un sujet à traiter : le déroulement des audits, présentant l'approche et la méthodologie d'audit.

Phases d'un audit

Le processus d'audit suit une démarche rigoureuse en trois ou quatre grandes étapes, conforme aux bonnes pratiques internationales (notamment ISO 19011, COBIT, ISACA).



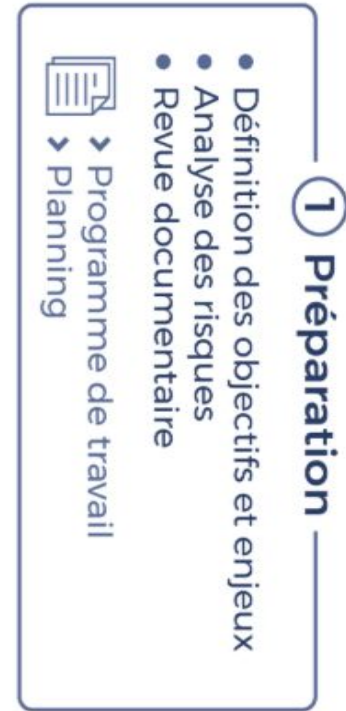
5. Méthodologie et Approche d'audit



5. Méthodologie et Approche d'audit

5.1. Planification

- Définition du périmètre et des objectifs
- Analyse des risques SI (pré-audit, contexte de l'organisation)
- Prise de contact avec les parties prenantes (RSSI, DSI, métiers)
- Élaboration du plan d'audit : calendrier, ressources, livrables attendus
- Validation de **la mission** avec la direction



5. Méthodologie et Approche d'audit

5.1. Planification - La préparation

Cette première phase de préparation a pour objet de :

Prendre connaissance des objectifs d'audit, du périmètre à auditer, et identifier les risques ainsi que le dispositif de contrôle ;

Construire et valider le référentiel d'audit ;

Élaborer le programme de travail et valider l'organisation de la mission.

Pour ce faire, vous allez vous appuyer sur les ressources documentaires existantes, afin de prendre connaissance de ce périmètre et cadrer la mission d'audit.

Vous devrez également identifier les acteurs et les personnes à solliciter dans le cadre de l'audit. Il en résultera un référentiel, ou grille d'audit, ainsi qu'un programme de travail.

5. Méthodologie et Approche d'audit

5.1. Planification - Réunion de lancement

La réunion de lancement permettra de réunir toutes les personnes qui seront sollicitées dans le cadre de l'audit et l'équipe qui réalisera la mission ; mais également de :

Partager et échanger autour des objectifs de la mission et du périmètre ;
Présenter l'équipe d'auditeurs, ainsi que leurs compétences et parcours.

Nous reviendrons sur la méthode d'élaboration d'une grille d'audit et l'organisation de la réunion de lancement, la semaine prochaine

5. Méthodologie et Approche d'audit

5.2. Réalisation

- Collecte de preuves : revue documentaire, interviews, observations, tests
- Analyse des écarts : identification des non-conformités, failles, pratiques à risque
- Élaboration de fiches d'écarts : description, impact, criticité
- Points de contrôle intermédiaires avec les audités (validation des constats)
- Utilisation éventuelle d'outils techniques : Nmap, Nessus, Wireshark, etc.



5. Méthodologie et Approche d'audit

5.2. Réalisation - L'investigation

Après avoir officialisé le lancement de l'audit et communiqué sur son déroulement, la phase d'investigation est l'occasion de rentrer dans le vif du sujet. Les objectifs de cette phase sont de :

Collecter les informations et constituer les preuves d'audit au moyen d'outils tels que les entretiens ou des analyses de données ;
Analyser les informations collectées et élaborer les recommandations.

À l'issue de cette phase, vous aurez une première version du rapport d'audit, dont les observations et les recommandations devront être validées par les audités.

Nous détaillerons cette phase et je vous présenterai des outils à utiliser dans le cadre des audits.

5. Méthodologie et Approche d'audit

3.3. Conclusion

- Rédaction du rapport final : constats, analyses, recommandations
- Présentation à la direction / parties prenantes
- Proposition d'un plan d'actions correctives
- Suivi post-audit : planification d'un audit de reprise ou de vérification

③ Validation

Démarche contradictoire
Validation des recommandations

➤ Version finale
du rapport d'audit

5. Méthodologie et Approche d'audit

5.3. Conclusion - La validation

La phase de validation est primordiale et parfois oubliée. Il s'agit de mettre en œuvre une démarche contradictoire pour donner l'opportunité aux audités de revenir sur certaines observations et recommandations, et de fournir aux auditeurs des compléments d'informations.

Dans certains cas, la démarche contradictoire se fait pendant la réunion de clôture.

Par expérience, lorsque les audités n'ont pas été tenus au courant des recommandations et qu'ils ne sont pas d'accord, ils l'expriment haut et fort !

Je vous présenterai les activités clés de cette phase dans la quatrième partie du cours.

Je vous proposerai également des outils pour rédiger le rapport d'audit et formuler vos recommandations, afin qu'elles soient percutantes.

5. Méthodologie et Approche d'audit

5.3. Conclusion - Suivi

La phase de suivi intervient après l'audit, lorsque les recommandations ont été traduites par des plans d'action à mettre en œuvre afin de maîtriser les risques et d'améliorer les dispositifs de contrôles, et in fine aider à atteindre les objectifs de l'entreprise.

En tant qu'auditeur, ou responsable de la fonction d'audit, vous ne pouvez pas participer à la mise en œuvre des plans d'action. On ne peut être juge et partie.

Néanmoins, il est possible de réaliser une mission de suivi des recommandations d'audit. Vous pourrez donc intervenir lorsque les plans d'action auront suffisamment avancé. Vous allez effectuer un audit de suivi des recommandations, en collectant de nouvelles informations et de nouvelles preuves.

Les recommandations seront alors mises à jour, voire clôturées, en fonction de l'avancement des actions.

6. Normes et pratiques de l'audit

Il existe plusieurs normes et méthodologies d'audit utilisées pour effectuer des audits de systèmes d'information (SI) afin d'assurer l'efficacité, la sécurité et la conformité des systèmes.

Chacune de ces méthodologies et normes a ses propres avantages, outils, et domaines d'application.

L'approche adoptée dépend souvent de la nature et de la portée de l'audit, des besoins spécifiques de l'organisation, ainsi que des réglementations et standards applicables à l'industrie ou au pays concerné.

6. Normes et pratiques de l'audit

Voici quelques-unes des normes et méthodologies d'audit les plus courantes :

1. ISACA (Information Systems Audit and Control Association) :**
 - COBIT (Control Objectives for Information and Related Technologies) :
 - Certification CISA (Certified Information Systems Auditor) :
2. ISO (Organisation Internationale de Normalisation) :**
 - ISO/IEC 27001 et ISO/IEC 27002 :
4. ITIL (Information Technology Infrastructure Library) :
6. Audit basé sur les risques :
8. NIST (National Institute of Standards and Technology) :

7. Élaboration de la charte d'audit et règles déontologiques

7.1. Charte d'audit

La charte est un document contractuel et éthique qui précise :

- Les objectifs de l'audit
- Les modalités d'exécution
- Les règles de confidentialité
- Les responsabilités des auditeurs et des audités
- Le périmètre d'accès aux données, aux systèmes, aux utilisateurs

Elle garantit l'adhésion des deux parties et protège l'indépendance de l'auditeur.

7. Élaboration de la charte d'audit et règles déontologiques

7.1. Charte d'audit

L'audit des systèmes d'information repose non seulement sur des méthodologies rigoureuses, mais aussi sur un cadre éthique et contractuel clair.

Ce cadre est formalisé par la charte d'audit, un document de référence signé entre les parties prenantes, et complété par des principes déontologiques que l'auditeur doit respecter tout au long de sa mission.

Définition

La charte d'audit est un document officiel, formel et structurant qui établit les règles du jeu entre les auditeurs et les audités. Elle constitue un engagement réciproque, garantissant le bon déroulement de la mission, tout en définissant les responsabilités, les limites d'intervention, et les principes de confidentialité.

7. Élaboration de la charte d'audit et règles déontologiques

Composant	Description
Objectifs de l'audit	Ce que la mission vise à évaluer : conformité, sécurité, performance, alignement stratégique...
Périmètre de l'audit	Systèmes, applications, processus, filiales ou fonctions concernées.
Modalités d'exécution	Méthodologie adoptée, planning, acteurs impliqués, format des livrables.
Règles d'accès	Conditions d'accès aux systèmes, données, infrastructures et personnel.
Confidentialité	Engagements sur la non-divulgence des informations sensibles ou stratégiques.
Responsabilités	Devoirs respectifs des auditeurs et des entités auditées, interlocuteurs désignés.
Référentiels appliqués	Normes, lois ou règlements encadrant l'audit (ISO 27001, RGPD, etc.).
Clauses de validation et de litige	Modalités de validation des constats et de traitement des désaccords.

7. Élaboration de la charte d'audit et règles déontologiques

7.2. Déontologie de l'auditeur

L'auditeur de SI doit respecter des principes éthiques fondamentaux :

- Indépendance vis-à-vis des objets audités
- Objectivité dans la formulation des constats
- Confidentialité des informations traitées
- Compétence (connaissances actualisées, impartialité)
- Intégrité dans ses relations avec l'organisation auditée

Ces principes sont notamment encadrés par l'ISACA (Code of Ethics) et les recommandations de l'IFACI.

7. Élaboration de la charte d'audit et règles déontologiques

7.2. Déontologie de l'auditeur

L'exercice de l'audit, notamment dans un domaine aussi sensible que les systèmes d'information, impose le respect de règles déontologiques strictes. Ces règles garantissent l'objectivité des constats et la crédibilité du processus.

Indépendance

L'auditeur ne doit entretenir aucun lien hiérarchique, commercial ou personnel avec les personnes ou processus audités. Cette indépendance garantit que les constats sont formulés sans conflit d'intérêt.

Objectivité

L'audit doit reposer sur des faits vérifiables, pas sur des jugements subjectifs. L'auditeur s'engage à analyser avec rigueur et neutralité, quels que soient les résultats.

7. Élaboration de la charte d'audit et règles déontologiques

7.2. Déontologie de l'auditeur

L'exercice de l'audit, notamment dans un domaine aussi sensible que les systèmes d'information, impose le respect de règles déontologiques strictes. Ces règles garantissent l'objectivité des constats et la crédibilité du processus.

Confidentialité

Les informations collectées lors de l'audit sont strictement confidentielles. L'auditeur s'engage à ne les utiliser que dans le cadre de la mission, et à respecter les politiques de sécurité en vigueur.

Compétence

L'auditeur doit disposer des compétences techniques, réglementaires et méthodologiques nécessaires à la mission. Il s'engage à se former régulièrement pour maintenir son niveau d'expertise.

Intégrité

L'auditeur agit avec honnêteté, loyauté et transparence. Il signale tout conflit d'intérêt potentiel, évite les faveurs ou avantages, et respecte les délais et les règles établies.

7. Élaboration de la charte d'audit et règles déontologiques

7.2. Déontologie de l'auditeur

L'exercice de l'audit, notamment dans un domaine aussi sensible que les systèmes d'information, impose le respect de règles déontologiques strictes. Ces règles garantissent l'objectivité des constats et la crédibilité du processus.

Référentiels de déontologie reconnus

- Code of Ethics de l'ISACA : encadre les pratiques des auditeurs certifiés CISA, CRISC, etc.
- Code de conduite de l'IFACI (Institut Français de l'Audit et du Contrôle Internes)
- Norme ISO 19011 : lignes directrices pour l'audit des systèmes de management

7. Élaboration de la charte d'audit et règles déontologiques

L'audit des systèmes d'information est un levier stratégique de maîtrise des risques numériques.

En s'appuyant sur des principes déontologiques stricts, des méthodes éprouvées, et des référentiels normatifs solides, il contribue à renforcer la transparence, la sécurité et la résilience des organisations.

La compréhension des types d'audit, des étapes de la mission, des livrables attendus et du cadre éthique permet d'aborder cette activité avec rigueur et efficacité, au service d'une gouvernance numérique responsable.